

Clase 003 — Frameworks de seguridad: NIST CSF, ISO 27001, MITRE ATT&CK y Diamond Model

Parte: **0 — Fundamentos y prerequisites** · Fuente: *NIST CSF 2.0 e ISO/IEC 27001:2022* 🕒 Duración estimada: **100 min** · Nivel: **Fundamentos**

Objetivo

Conocer los marcos que estructuran la práctica profesional de la ciberseguridad y saber cuándo usar cada uno. Al terminar podrás ubicar cualquier control o técnica dentro de un framework, entender la diferencia entre un marco de gestión (CSF, ISO) y un marco de conocimiento adversario (ATT&CK, Diamond), y usarlos juntos.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Enumerar** las funciones del NIST CSF 2.0 y explicar qué agrupa cada una.
2. **Describir** el propósito y la estructura de ISO/IEC 27001 y su Anexo A.
3. **Navegar** la matriz de MITRE ATT&CK por tácticas y técnicas.
4. **Analizar** un evento con el Diamond Model de intrusión.
5. **Combinar** un marco de gestión con uno adversario en un caso real.

Temas

#	Tema	Por qué importa
1	NIST CSF 2.0	Lenguaje común de gestión de riesgo, ahora con Govern
2	Tiers y perfiles	Cómo medir madurez y fijar objetivos
3	ISO/IEC 27001	Estándar certificable del SGSI
4	Anexo A (27002)	Catálogo de controles de referencia
5	MITRE ATT&CK	Base de conocimiento de TTP adversarios
6	Diamond Model	Análisis de intrusiones en 4 vértices
7	Mapeo entre marcos	Ninguno basta solo; se complementan
8	Cumplimiento vs. seguridad	Cumplir no es estar seguro

Definiciones y características

- **NIST CSF 2.0:** marco voluntario de gestión de riesgo con seis funciones (Govern, Identify, Protect, Detect, Respond, Recover). Clave: agnóstico de tecnología, orientado a resultados.

- **SGSI**: Sistema de Gestión de Seguridad de la Información, el objeto de ISO 27001. Clave: enfoque de mejora continua (PDCA).
- **Anexo A / ISO 27002**: catálogo de 93 controles (versión 2022) agrupados en 4 temas. Clave: es referencia, no obligación total; se seleccionan según riesgo.
- **MITRE ATT&CK**: matriz de tácticas (el *porqué*) y técnicas (el *cómo*) del adversario. Clave: basada en observaciones reales.
- **Diamond Model**: modelo que relaciona adversario, capacidad, infraestructura y víctima en cada evento de intrusión. Clave: pivota entre vértices para descubrir más del ataque.
- **Perfil (CSF)**: fotografía del estado actual vs. objetivo de las funciones del marco. Clave: herramienta de priorización.

Herramientas y preparación

Descarga el **NIST CSF 2.0** (PDF gratuito). Explora la **matriz de MITRE ATT&CK** en el navegador, incluido el **ATT&CK Navigator** (<https://mitre-attack.github.io/attack-navigator/>) para crear *heatmaps*. Para ISO, consulta el índice público del Anexo A. Opcional: hoja de cálculo para mapeos. Sin laboratorio ofensivo.

Laboratorio guiado (ejercicio aplicado)

1. **CSF**: toma una organización ficticia (una clínica pequeña) y para cada una de las 6 funciones del CSF 2.0 escribe una actividad concreta que debería realizar.
2. **Perfil actual vs. objetivo**: asigna a cada función un nivel del 1 al 4 (actual) y otro (deseado). Identifica la mayor brecha.
3. **ISO mapeo**: selecciona 5 controles del Anexo A relevantes para esa clínica y justifica cada uno con un riesgo.
4. **ATT&CK Navigator**: crea una capa marcando 5 técnicas que un ransomware usaría contra la clínica. Exporta el JSON.
5. **Diamond**: para un evento hipotético (correo malicioso a la recepcionista), rellena los 4 vértices: adversario, capacidad (el malware), infraestructura (dominio/IP), víctima.
6. **Integración**: muestra cómo una técnica de ATT&CK detectada se conecta con una función del CSF (Detect) y con un control ISO.

Ejercicios

1. ¿Qué función nueva añadió el CSF 2.0 respecto a 1.1 y por qué importa?
2. Explica la diferencia entre una táctica y una técnica en ATT&CK con un ejemplo.
3. Da tres controles del Anexo A y clasifícalos en su tema (organizacional, personas, físico, tecnológico).
4. Analiza un incidente sencillo con el Diamond Model y muestra un "pivote" entre dos vértices.
5. ¿Por qué "cumplir ISO 27001" no equivale a "estar seguro"? Argumenta.
6. Mapea una técnica ATT&CK a la función del CSF que ayudaría a mitigarla.

Reto verificable

Produce un documento que integre los cuatro marcos sobre un mismo escenario: (1) perfil CSF actual/objetivo con 6 funciones, (2) selección justificada de 8 controles del Anexo A, (3) una capa de ATT&CK Navigator con ≥ 6 técnicas exportada como JSON, y (4) un análisis Diamond de un evento del escenario.

Criterio de aceptación: el JSON del Navigator carga sin errores en la herramienta oficial, cada control ISO se vincula a un riesgo, y cada técnica ATT&CK se conecta con al menos una función del CSF. El documento demuestra que gestión y conocimiento adversario se refuerzan.

⚠ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Usar ATT&CK como checklist de cumplimiento	ATT&CK describe comportamiento adversario, no es una lista de controles a "tachar".
Confundir ISO 27001 con 27002	27001 es el estándar certificable del SGSI; 27002 es la guía de controles.
Certificar por certificar	El cumplimiento sin gestión de riesgo real deja huecos; la seguridad es continua.
Elegir un solo framework para todo	Los de gestión (CSF/ISO) y los adversarios (ATT&CK/Diamond) resuelven problemas distintos.
Ignorar la nueva función Govern	Gobernanza y contexto son ahora explícitos en CSF 2.0; no la omitas.

? Preguntas frecuentes

? **¿NIST CSF es obligatorio?** No, es voluntario, pero se ha vuelto un lenguaje común, y en muchos sectores/países es de facto exigido por contratos o reguladores.

? **¿ATT&CK sustituye a la Kill Chain?** No; ATT&CK detalla técnicas y la Kill Chain da la vista por fases. Se usan juntas.

? **¿Puedo usar solo ATT&CK sin marcos de gestión?** Para operaciones defensivas sí ayuda, pero sin CSF/ISO faltaría la capa de gobernanza, riesgo y cumplimiento.

? **¿El Diamond Model es solo para forense?** Es útil en análisis de intrusiones y *threat intelligence*, no solo forense; ayuda a pivotar y correlacionar campañas.

🔗 Referencias

- NIST CSF 2.0 — <https://www.nist.gov/cyberframework>
- ISO/IEC 27001:2022 — <https://www.iso.org/standard/27001>
- MITRE ATT&CK y Navigator — <https://attack.mitre.org/>
- Caltagirone, Pendergast & Betz, *The Diamond Model of Intrusion Analysis* — <https://www.activeresponse.org/the-diamond-model/>

➡ Siguiente clase

Clase 004 - Montaje del laboratorio: virtualizacion, Kali, snapshots y aislamiento de red